FUZE FINANCE | HALBORN

A JOINT PAPER • SEPTEMBER 2026

SECURITY-FIRST DIGITAL ASSET INFRASTRUCTURE

A Blueprint for Banks and Custodians

Operating models, custody architecture, and the security standard that underpins institutional digital asset programs.

WHY SECURITY-FIRST - BY THE NUMBERS

$1.5B
Largest digital-asset theft in history - Bybit, 2025

$625M
Ronin validator-key compromise

$223M
Cetus exploit from a single code constant

43.8%
of 2024 stolen value via private-key compromise

Sources: Halborn incident analyses; Chainalysis (2025). Figures from this paper's case studies.

Contents

Executive Summary 03

1. Introduction 04

2. The Threat Landscape for Banks and Custodians 05

3. Choosing the Right Operating Model 09

4. Trading Infrastructure: What Banks Need to Know 14

5. Custody Architecture & Key Management 17

6. Operational Security & Internal Controls 24

7. Smart Contract & Protocol Risk 28

8. Regulatory Alignment by Design 32

9. Vendor & Third-Party Risk Management 40

10. The Blueprint: A Maturity Model for Banks 44

11. Recommendations 47

12. Conclusion 50

Appendices 51

Executive Summary

The integration of digital assets into traditional banking is no longer a question of “if” but “when” and “how”. Regulatory clarity is advancing across every major financial jurisdiction, from MiCA’s full entry into force across the EU to VARA’s maturation in Dubai, the OCC’s progressive interpretive letters in the United States, and Switzerland’s established SO-FIT/AMLA pathway. The conditions that historically justified a "wait and see" approach for banks have shifted in the last few years. Institutions that delay now risk ceding client relationships, fee revenue, and product relevance to competitors who have already moved.

Fuze Finance provides the regulated infrastructure layer that allows banks and custodians to enter this market on a defined timeline, without building proprietary technology from scratch. This paper sets out the framework Fuze Finance and Halborn have developed together: the operating model decisions banks face, the infrastructure required to support institutional-grade operations, and the security architecture that must underpin both.

The central argument is straightforward. A bank can choose between two primary go-to-market structures: a fully disclosed model, in which the bank’s identity and Fuze Finance role as execution infrastructure are both transparent to the

end client; and, a white-label model, in which the bank goes to market entirely under its own brand while Fuze Finance stack operates beneath it. These are not competing options: they represent different positions on a maturity curve, and most institutions migrate between them as their digital asset capability develops. What does not change between models is the security and compliance standard required. Regardless of how a bank goes to market, the same threats exist, the same regulators are watching, and the same clients are at risk if the infrastructure fails.

Introduction

01

The institutional shift toward digital assets

Institutional adoption of digital assets has crossed from pilot programs into mainstream banking product strategy across Europe, the Middle East, and North America. Banks are now asking how to structure the digital asset offering, which operaring model minimized execution risk, and how quickly they can reach the market without compromising compliance or security.

The driver is client demand that can no longer be deferred. High-net-worth and mass-affluent clients are already holding digital assets through unregulated or lightly regulated channels. Institutional investors are seeking regulated custody and execution venues. Corporate treasury functions are exploring digital asset settlement rails. The bank that does not provide a compliant, bank-grade product does not eliminate its clients' exposure to digital assets, it simply removes itself from that relationship.

How Fuze Finance and Halborn complement each other

Fuze Finance role in this framework is the go-to-market and infrastructure layer: the operating model design, the execution and settlement infrastructure, the compliance tooling embedded in the transaction flow, and the connectivity to regulated custody providers and liquidity sources. Halborn's role is the security architecture and assurance layer: the threat modeling, the audit and penetration testing regime, and the ongoing monitoring and incident response framework. This combination of strong go-to-market architecture, operationally robust infrastructure and rigorous security controls provides banks with assurance from day one.

This paper is structured to address both layers in sequence, and to make explicit where they intersect — particularly in custody architecture, regulatory alignment, and vendor risk management.

02

The Threat Landscape for Banks and Custodians

Digital asset infrastructure introduces a fundamentally different risk profile from traditional financial systems. While banks have decades of experience managing credit, market, and operational risks in closed, permissioned environments, digital assets operate on public, immutable blockchains where transactions become irreversible once confirmed on-chain. As a result, a single point of failure can lead to instantaneous and irrecoverable loss, with no central authority available to intervene.

Unique attack vectors in digital asset environments

Banks and custodians entering this space must address several attack vectors that are either rare or materially different in traditional finance. Taken together, these vectors create an exposure profile that requires dedicated security architecture rather than a simple adaptation of existing controls.

Private key compromise

The private key serves as the sole credential controlling access to digital assets. Unlike traditional banking credentials, which support reset mechanisms, multi-factor authentication, and chargeback options, a compromised private key grants the attacker permanent and direct control. Hot wallets required for liquidity and continuous operations face particular exposure. Even sophisticated multi-signature or multi-party computation setups can fail when key generation, storage, or signing procedures contain weaknesses. For instance, private key compromises accounted for the largest share of stolen crypto value across centralized services in 2024 at 43.8 percent (Chainalysis, 2025).

Smart contract exploits

When integrating tokenized assets, DeFi protocols, or on-chain settlement logic, vulnerabilities in smart contract code such as reentrancy bugs, flawed access controls, or oracle manipulation can be exploited rapidly. These attacks frequently combine with flash loans to drain liquidity pools or manipulate collateral within seconds. Traditional securities settlement systems face no equivalent risk of instantaneous, code-driven extraction.

Insider threats

Employees or contractors with privileged access to signing systems, custody platforms, or administrative keys represent an elevated risk. High-value assets, combined with remote work environments and occasionally immature institutional controls, have enabled multiple incidents in which insiders or compromised insider credentials facilitated large-scale theft.

Security threats by third-party vendors

Most banks rely on external custody providers, liquidity partners, API infrastructure, and analytics tools that operate outside their core systems. A compromise at any point in this chain can propagate directly to client assets, which is why supply chain attacks targeting widely used infrastructure components have emerged as a dominant vector.

Attack Vector	Traditional Finance	Digital Assets	Relative Risk Level
Private Key / Credential	Reset possible, chargebacks	Irreversible control	High
Smart Contract / Code	Limited exposure	Rapid, automated exploitation	Very High
Insider Threats	Contained by internal controls	Direct asset access	High
Third-Party / Vendor	Contractual remedies	Direct propagation to client assets	Very High

- Threat Vector Comparison: Traditional Finance vs. Digital Assets

How do these threats differ fundamentally from traditional financial system threats

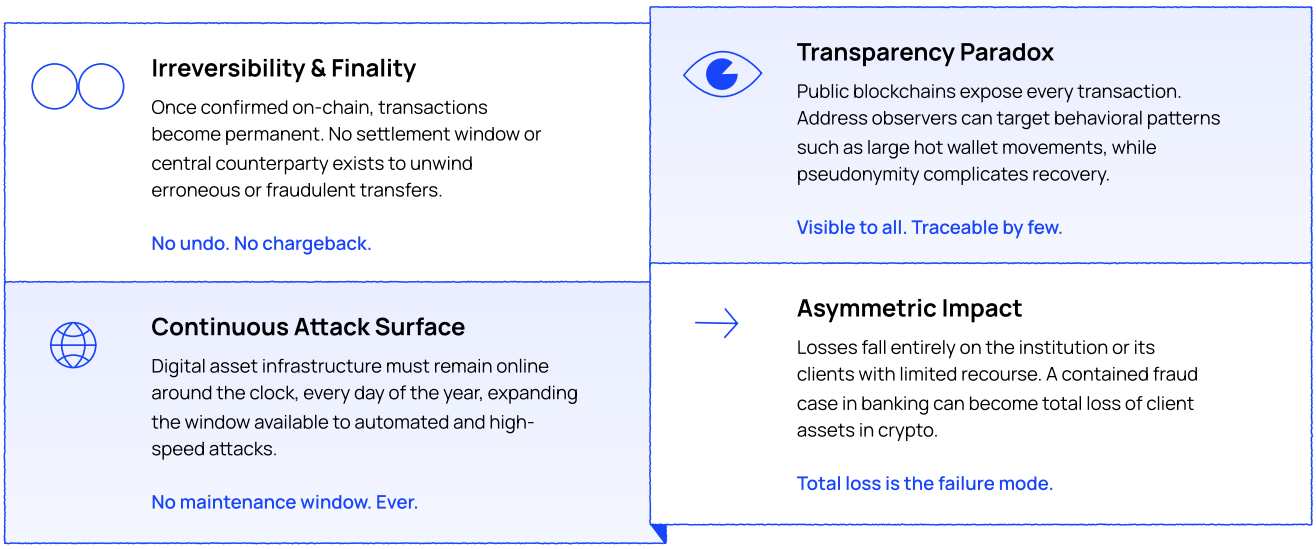
Traditional banking threats can usually be mitigated through established controls such as fraud detection with chargebacks, centralized settlement with defined finality windows, regulatory resolution mechanisms, and insurance frameworks. Digital assets, however, differ in four critical dimensions that fundamentally alter the risk equation.

- **Irreversibility and finality:** Once a transaction receives on-chain confirmation, it becomes permanent in most cases. No settlement window or central counterparty exists to unwind erroneous or fraudulent transfers.
- **Transparency paradox:** Public blockchains expose every transaction. This visibility allows attackers to observe and target behavioral patterns such as large hot wallet movements, while pseudonymity complicates tracing and recovery efforts.
- **Continuous global attack surface:** Digital asset infrastructure must remain online around the clock, every day of the year, which expands the window available for automated and high-speed attacks.
- **Asymmetric impact:** Losses fall entirely on the institution or its clients with limited recourse. A breach that might result in a contained fraud case in traditional banking can produce total loss of client assets together with severe reputational and regulatory consequences.

> In summary, these characteristics require banks and custodians to adopt a security-first architecture from day one. Effective protection therefore depends on defense-in-depth, continuous verification, and institutional-grade operational controls rather than reliance on any single safeguard.

Four Dimensions That Alter the Risk Equation

How digital asset threats differ fundamentally from traditional finance



Source: Halborn

- Four Dimensions That Alter the Risk Equation — how digital asset threats differ fundamentally from traditional finance

CASE STUDY

The Bybit Hack, February 2025: $1.5 Billion via Signing Interface Compromise

Anatomy of a real exchange or custodian breach: what failed and when

In February 2025, Bybit suffered the largest theft in the history of digital assets: approximately $1.5 billion drained from its ETH cold wallet in a single coordinated attack. Attributed to North Korea's Lazarus Group, the incident is the most instructive recent example of how a digital asset custodian can fail, and why the failure point is rarely where institutions expect it.

What failed

Bybit's ETH cold wallet was protected by a Safe multisig requiring multiple independent signers, an institutional-grade arrangement. The smart contracts themselves were uncompromised. The attack succeeded at the signing interface layer, not the protocol layer. Halborn's post-incident analysis identified that the Lazarus Group social-engineered a Safe infrastructure developer, gaining access to Safe's AWS-hosted front-end code. The attacker injected malicious JavaScript into the signing UI. When Bybit's three signers connected to approve what appeared to be a routine ETH transfer from cold to hot wallet, they each loaded a trojanized version of the interface. The malicious code detected the transaction type, silently modified it to include a delegatecall that would upgrade the multisig proxy to an attacker-controlled contract, and presented the original, legitimate-looking transaction details to the signers' hardware wallets. All three signed. The transaction executed on-chain as modified, not as displayed.

When

The attack was executed on 21 February 2025. Forensic investigation confirmed the Safe front-end had been compromised days earlier, with the malicious code dormant until a qualifying transaction was detected.

The systemic failures

No independent transaction verification existed outside the browser-rendered UI. There was no mechanism to verify the integrity of the Safe front-end before use. The supply chain attack surface (third-party infrastructure providers whose compromise can intercept multisig signing workflows) was absent from the threat model. The attack succeeded without breaking a single cryptographic primitive. The multisig held. The interface did not.

What the architecture should have included

Interface integrity verification (hash-verified front-ends or hardware-enforced transaction display independent of the browser); independent transaction simulation before signing to confirm on-chain effect against stated intent; and supply chain security requirements applied to every component in the signing workflow, not only the smart contracts. For banks operating institutional custody, vendor risk management applied to a custody infrastructure provider must include the security of that provider's own tooling and deployment pipeline.

- Sources: Halborn, "Explained: The Bybit Hack (February 2025)"; "How the Bybit Hack Happened — and How to Prevent the Next One with Seraph" (March 2025); "Smart Contract Audits Won't Stop Off-Chain Attacks" (March 2025). halborn.com.

The threat landscape outlined in Section 2 shapes every infrastructure decision that follows. Understanding which attack vectors are most likely to affect a bank's operations is not a theoretical exercise — it is the prerequisite for making rational choices about operating model, custody architecture, and vendor selection. The sections below address those choices in sequence.

03

Choosing the Right Operating Model

Banks entering the digital asset space face a foundational question before any technology or compliance decision: how do they want to go to market? The answer depends on regulatory obligations, infrastructure requirements, revenue economics, and the speed at which they can launch. We at Fuze Finance believe that there are two primary models to consider, with a hybrid path for institutions that want to evolve incrementally.

3a. Fully Disclosed Model

In the fully disclosed model, the bank operates under its own brand with complete transparency to the end client. The client knows they are transacting with the bank, that holds a direct relationship with them and takes on regulatory accountability for onboarding, suitability, and reporting. The underlying infrastructure, which enables transaction execution, settlement, liquidity sourcing, and compliance workflows, is provided by a VASP/ Financial Intermediary (such as Fuze Finance), operating as a technology and infrastructure partner in the background.

Under this arrangement, the bank's identity is clearly positioned upfront with the customer, while Fuze Finance's role is disclosed to the end client as the underlying infrastructure provider, meaning execution terms, pricing, and the identity of the infrastructure layer are transparent through the bank's own reporting.

What the bank owns

- The client relationship and all KYC/AML obligations for that client
- Suitability and conduct obligations under applicable financial services regulations
- The brand experience and client-facing interface
- Reporting obligations to the regulator

What Fuze Finance provides

- Agency-only execution across multiple liquidity providers via a Smart Order Router
- Settlement infrastructure and end-of-day reconciliation
- On-chain analytics (KYT via Chainalysis, for instance) and compliance tooling embedded in the transaction flow
- Fiat on-/off-ramp connectivity
- Reporting data shared back to the bank's systems via API connectivity

Best suited for: large banks and private banking institutions that already have compliance infrastructure, established client relationships with sophisticated investors, and the internal bandwidth to own regulatory accountability for client-level transactions. In Switzerland, this model maps directly to the SO-FIT regulated intermediary framework under AMLA, where Fuze Finance (Switzerland) AG, which completed the SO-FIT affiliation process in July 2026, will act as the disclosed execution partner.

Revenue and margin structure: the bank earns the spread or commission on client-facing pricing, with Fuze Finance charging a wholesale execution fee and platform fee negotiated at partner level. The bank controls its own margin. Execution fees are transparent and can be disclosed to the end client through the bank's reporting.

Client experience: the client sees a bank-branded product with full transparency on who is executing and on what terms. For HNWI and private banking clients, this is often preferable, as they want the familiarity of their primary banking relationship combined with access to a regulated execution venue.

CASE STUDY

Fuze Finance x Wio Bank, United Arab Emirates

In November 2023, Wio Bank became the first bank in the UAE to launch digital asset trading in partnership with Fuze Finance, leveraging Fuze Finance's Wealth solution to provide customers with access to digital asset trading through the bank's existing digital banking app.

Fuze Finance provided the underlying digital asset trading infrastructure, enabling Wio to offer the service under a Fully Disclosed model, with Fuze Finance's role as the regulated digital asset infrastructure and execution partner clearly disclosed to customers.

Fuze Finance can support both closed-loop and open-loop operating models, providing flexibility to tailor the solution to the bank's regulatory and product requirements. For Wio, the implementation progressed from integration to go-live in just six weeks.

Wio retained ownership of the customer relationship, banking interface, brand experience and distribution, while Fuze Finance provided the technology, digital asset trading capabilities, liquidity and execution infrastructure required to operate the service.

The Wio implementation demonstrates three key aspects of Fuze Finance's model: (i) banks can launch digital asset trading rapidly without building the underlying infrastructure in-house; (ii) Fuze Finance's flexible orchestration layer can support different operating models, including Fully Disclosed structures, while maintaining clear allocation of responsibilities between the bank and Fuze Finance; and (iii) a trusted digital banking interface can enable banks to introduce digital assets as an integrated extension of their existing financial services proposition.

3b. White-Labeled Model

In the white-label model, conversely, Fuze Finance provides the full technology stack for trading, settlement, custody integrations, compliance workflows, and reporting and the bank goes to market entirely under its own brand. Clients interact only with the bank's interface. Fuze Finance's infrastructure operates invisibly beneath it.

What the bank owns

- The brand and client-facing product
- The commercial decision on pricing and product scope
- Its own regulatory authorizations. The white-label model does not transfer Fuze Finance's regulatory permissions to the bank; the bank operates under its own license or registration in each distribution jurisdiction.

What Fuze Finance provides:

- APIs covering trade execution, settlement, compliance workflows, and reporting
- Testing environment for pre-launch testing and integration validation
- Smart Order Router connecting to multiple licensed liquidity providers with best-execution logic
- Webhook-based real-time notifications integrated with the bank's systems
- White-label UI capability or pure API-first integration for banks with existing front-ends
- On-chain analytics (e.g., KYT via Chainalysis) embedded in the transaction flow
- Modular infrastructure to activate services and features as per the bank's needs (ex. vaults, lending, multiple tokens choice, etc.

Best suited for: regional banks, neo-banks, and financial institutions in emerging markets that want to offer digital asset services without the build cost, timeline, or technical complexity of internal infrastructure. This model is relevant for established banks that want to test demand in a new market before committing to a fully disclosed architecture and the related implementation.

Speed to market: API-first integration with testing optionality means production-ready deployments are achievable in a materially shorter timeframe than internal builds. At Fuze Finance, white-label crypto integrations typically take 90 to 120 days from integration commencement to first live transaction, depending on core banking system complexity and internal integration resources.

Regulatory note: the white-label model does not automatically transfer regulatory permissions. The bank must hold its own applicable authorizations for the jurisdictions in which it distributes. Fuze Finance's infrastructure is the execution and settlement layer; the regulatory obligations for client-facing activities still lie with the bank. This distinction is material under MiCA in the EU, under VARA in Dubai, and under the AMLA/SO-FIT framework in Switzerland, to make a few notable examples.

3c. Hybrid Approaches

Most banks that build a long-term digital asset business do not remain permanently in one model. The white-label model is typically a starting position, it reduces entry risk, shortens the path to first revenue, and lets the bank validate client demand before committing capital to internal infrastructure. Over time, as volumes grow, regulatory comfort increases, and institutional capability develops, banks may opt for migrating components of their digital asset business from a white-label, fully disclosed model toward an in-house stack.

How the transition typically works

A bank starts on the white-label model with closed-loop transactions. After demonstrating operational stability and building internal compliance familiarity with digital asset transaction monitoring, it may activate open-loop functionality, enabling client wallet connectivity and broader asset support. As client volumes scale, it may move toward the fully disclosed model, disclosing Fuze Finance's role more explicitly, or begin internalizing specific components (custody integrations, reporting, or liquidity relationships) while maintaining Fuze Finance's execution layer.

The decision framework has three dimensions

01. **Regulatory environment.** Jurisdictions with clear licensing categories, e.g., MiCA in the EU, VARA or CMA in the UAE, SO-FIT/AMLA in Switzerland, allow banks to make stable infrastructure decisions. Markets with evolving or fragmented regulation favor remaining on white-label infrastructure that can adapt as rules develop, rather than committing early to architecture that may need restructuring.

02. **Technical maturity.** A bank without a dedicated digital asset engineering team should avoid internalizing infrastructure components it cannot maintain, audit, or secure. The white-label model is not a temporary shortcut; for many regional banks, it is the best long-term approach.

03. **Risk appetite.** The fully disclosed model places regulatory accountability for client-level conduct on the bank. Institutions with mature compliance programs, experienced AML officers with digital asset familiarity, and robust transaction monitoring capabilities can absorb this. Institutions still building those capabilities should remain in the white-label model until they can demonstrate operational readiness.

The hybrid path also covers partial disclosure arrangements, where Fuze Finance's role is disclosed at the institutional partner level (in the bank-to-Fuze Finance agreement and in regulatory filings) but not necessarily communicated in real time to the bank's end clients in the same way as the fully disclosed model. This is the case for many B2B2C delivery models where the end client transacts with the bank, the bank uses Fuze Finance infrastructure, and Fuze Finance's identity as the infrastructure provider is documented in the bank's regulatory framework.

The operating model a bank selects determines the commercial and regulatory structure of its digital asset product. It does not, on its own, determine the security posture. The trading infrastructure beneath both models must meet the same institutional standard, and the mechanics of digital asset markets introduce specific operational requirements that banks need to understand before going live.

04

Trading Infrastructure: What Banks Need to Know

Banks integrating digital asset trading need to understand that the mechanics of this market differ materially from traditional securities or FX markets. Infrastructure must operate continuously, across a fragmented liquidity landscape, without the centralized clearing counterparties that traditional markets rely on.

Institutional liquidity: how it works in practice

There is no single consolidated order book for digital assets equivalent to a regulated exchange in traditional securities. Institutional liquidity is sourced from a combination of OTC desks operated by market makers, electronic communications networks (ECNs), and liquidity aggregators that pool quotes from multiple venues. For a bank, directly managing multiple bilateral liquidity provider relationships introduces significant operational complexity, such as credit agreements, settlement logistics, collateral management, and counterparty risk assessment for each provider.

Fuze Finance's approach is to remove this complexity through a Smart Order Router (SOR) that queries multiple licensed liquidity providers simultaneously and selects the optimal execution strategy based on price, settlement terms, and counterparty reliability. The bank integrates once with Fuze Finance's API and accesses aggregated institutional liquidity without maintaining individual LP relationships. Supported payment and settlement rails include SWIFT (multi-currency, global), SEPA and SEPA Instant Credit Transfer (EUR), SIC and SIC Instant Payments (CHF), and Fuze Finance's own stablecoin settlement rails. For digital asset execution specifically, the OTC desk infrastructure provides a Request-for-Quote (RFQ) system enabling institutional clients to source competitive pricing across multiple LPs with a full auditable quote trail.

Best execution

Best execution in digital assets refers to the outcome that takes into account price, costs, speed, and likelihood of execution, applies to any bank operating under conduct-of-business rules. Fuze Finance's SOR architecture is designed to demonstrate best execution: the routing logic selects based on defined parameters, every routing decision is logged, and full quote trails are available for audit. Fuze Finance generates an immutable (i.e., tamper-evident and time-stamped) audit log of all platform events including execution decisions, available for regulatory and client reporting.

Settlement in a 24/7 market

Traditional securities settle on a T+1 or T+2 cycle with defined cutoffs. Digital asset markets run continuously, and settlement finality depends on the underlying blockchain network's confirmation mechanics. Fuze Finance operates a settlement engine that provides atomic processing of digital asset and fiat legs, meaning both sides of a trade settle simultaneously rather than sequentially, eliminating the settlement risk that arises when one leg completes before the other. End-of-day net settlement reports are generated for both fiat and digital asset legs, integrating with the bank's reconciliation processes.

Client funds held during the payment execution cycle are maintained in segregated accounts with licensed banking partners, separated from Fuze Finance's operating funds, and held for the minimum period necessary to complete settlement.

Fiat on-/off-ramp

One of the most operationally complex components of a digital asset product for a bank is the fiat on-/off-ramp, i.e., the conversion between fiat currency and digital assets at the point of client purchase or sale. Fuze Finance's on-ramp converts fiat to digital assets with full pricing transparency. Predictive cash flow models forecast intraday and end-of-day positions, enabling proactive liquidity pre-positioning to minimize conversion slippage and optimize timing. The off-ramp converts digital assets back to fiat with settlement into the client's account.

Pre-trade risk controls

Banks must apply risk controls to digital asset trading equivalent to those applied to traditional asset classes. Fuze Finance's infrastructure includes:

- Pre-trade limit enforcement (position limits and transaction size limits set by the bank at client or aggregate level)
- AI-driven anomaly detection that flags unusual transaction patterns before execution proceeds
- Real-time AML screening against sanctions lists and PEP databases at the point of each transaction
- KYT (Know Your Transaction) on-chain analytics via Chainalysis applied to all virtual asset flows before settlement
- High-risk transaction flagging for compliance review, with automated alert triage and risk scoring

For digital asset types, Fuze Finance applies a listing policy under which all supported assets are subject to legal and compliance review prior to activation. Assets that qualify as securities under applicable law, or that present elevated AML risk (such as privacy tokens), are excluded.

CASE STUDY

Deutsche Bank x Taurus, Global Infrastructure Partnership

Deutsche Bank, Germany's largest bank with over EUR 1.3 trillion in assets, partnered with Taurus, a Swiss-based digital asset infrastructure provider, to establish digital asset custody and tokenization services in September 2023. Deutsche Bank integrated Taurus's technology to manage cryptocurrencies and tokenized assets for corporate and institutional clients across multiple booking centers, without building proprietary infrastructure internally.

The partnership followed Deutsche Bank's participation in Taurus's USD 65 million Series B funding round in February 2023. The bank had applied to Germany's financial regulator BaFin for a crypto custody license in June 2023.

The case shows that a major global bank chose to integrate an external infrastructure provider's custody and execution technology rather than build internally, following a rigorous selection and due diligence process. This is a common pattern for banks entering digital assets today, often resorting to external providers for custody and execution infrastructure, while keeping the bank's own team focused on client relationships, risk management, and regulatory compliance.

- Sources: Taurus SA press release, September 14, 2023 (taurushq.com); CoinDesk, September 14, 2023; Invezz, September 14, 2023.

05

Custody Architecture & Key Management

5a. Custody Models Available to Banks

Custody is not a single decision, it is a set of interconnected choices covering who holds the private keys, under what legal and operational framework, with what level of segregation, and how the custody arrangement integrates with execution.

Three primary custody models

Self-custody: the bank generates and controls its own private keys, manages wallet infrastructure internally, and bears full operational and security responsibility for key management. This requires significant internal capability: secure key generation procedures, hardware security module (HSM) deployment, multi-signature authorization workflows, and a security operations function capable of continuous monitoring. Self-custody is the highest control option but also the highest-cost and highest-risk model to operate poorly. It is appropriate only for institutions with a mature security engineering function and a long-term commitment to digital asset infrastructure investment.

Third-party qualified custody: the bank works with a regulated custody provider that holds private keys on behalf of clients under an applicable regulatory authorization. In Switzerland, this includes FINMA-regulated entities such as AMINA Bank and Sygnum Bank. In the US, the OCC confirmed through a series of interpretive letters, most recently IL 1184 (May 2025) and IL 1186 (November 2025), that national banks may provide crypto asset custody services and may outsource permissible custody and execution activities to third parties, subject to appropriate third-party risk management. In Germany, BaFin issued its first crypto custody licenses to traditional financial institutions from 2023 onward. Third-party custody reduces the bank's operational burden and security exposure but introduces counterparty dependency and requires robust vendor due diligence and contractual protections.

Hybrid custody: combines elements of both. The bank may hold operational hot wallet infrastructure internally for transaction processing while using a third-party cold storage solution for the majority of assets. Alternatively, the bank may custody some asset types internally and rely on a third-party provider for others based on risk profile.

How custody integrates with Fuze Finance's operating models

In the **white-label model,** Fuze Finance connects to regulated third-party custody providers - leveraging internationally recognized custodians such as Fireblocks and HexTrust - as part of our integrated infrastructure stack. Client assets are held in segregated wallets through these custody partners, with a minimum percentage (usually around 80%, with best practice ranging to 95%) in cold (offline) storage and multi-signature controls required for all withdrawal authorization. The bank's clients benefit from institutional-grade custody without the bank needing to build or manage that infrastructure directly.

In the **fully disclosed model**, the custody arrangement is documented explicitly with the end client and the banking partner. Fuze Finance acts as execution agent; custody is handled by a regulated custody partner; the banking partner retains visibility into the custody structure and its regulatory treatment. Asset segregation is maintained throughout, with client tokens being held in wallets segregated by client or client group, separated from Fuze Finance's own operational holdings.

Segregation of client assets and proof of reserves

Client asset segregation is a non-negotiable operational requirement. Fuze Finance maintains segregated accounts for client funds in payment services (held with licensed Swiss banking partners, subject to daily reconciliation) and segregated wallets for digital assets in custody (through regulated custody partners). Client assets are never commingled with Fuze Finance's own operating funds or with assets held for other clients.

The custody model choice outlined above determines the legal and operational framework for asset holding. It does not, by itself, determine whether assets are actually secure. The technical controls beneath that framework — how keys are generated, stored, and authorized — are what prevent the custody arrangement from becoming a liability. Halborn's analysis below addresses the specific technical architecture that institutional custody requires.

5b. Technical Security of Custody

Effective custody architecture forms the foundation of any institutional digital asset program. While Fuze Finance integrates with regulated third-party custodians in both operating models, banks must understand the underlying technical controls that protect client assets. At its core, secure custody balances operational accessibility with uncompromising protection against private key compromise and unauthorized access.

Wallet storage architecture: hot, warm, and cold

Institutions typically implement a tiered storage strategy that allocates assets according to liquidity needs and risk tolerance. Cold storage keeps private keys completely offline in air-gapped environments, which delivers the highest level of protection against remote attacks. Warm wallets maintain limited connectivity for controlled operations, while hot wallets remain online to support real-time transaction execution and liquidity provision.

Best practice for banks calls for the vast majority of client assets, often 80 to 95 percent, to remain in cold storage at all times. Only the minimum amount required for daily settlement and client withdrawals should reside in hot wallets, with strict limits enforced through pre-trade controls and real-time monitoring. This tiered model minimizes exposure while preserving the speed required for a competitive offering.

Tiered Wallet Architecture

Asset allocation by storage tier with security controls at each layer

COLD

80-95% of assets

Offline / Air-gapped

CONNECTIVITY: NONE

Use case: long-term client holdings, reserve assets. Private keys never touch networked systems.

CONTROLS

- Air-gapped HSMs
- Geographically diverse distribution
- Multi-party ceremonies
- Physical security

Highest protection against remote attacks. Withdrawal requires formal multi-approval process.

↓ **Scheduled replenishment only**

WARM

5-15% of assets

Limited connectivity

CONNECTIVITY: CONTROLLED

Use case: settlement buffers, scheduled operations, intraday liquidity staging.

CONTROLS

- MPC signing
- Policy engine gating
- Time-delayed transfers
- Dual approval minimum

Bridges cold reserves and hot operations without exposing the majority of assets.

↓ **Limit-enforced top-ups**

HOT

‹5% of assets

Always online

CONNECTIVITY: CONTINUOUS

Use case: real-time execution, client withdrawals, daily settlement.

CONTROLS

- TXN balance ceilings
- Per-tx rate limits
- Real-time monitoring
- Velocity checks
- Anomaly alerts

Minimum required for operations only. Highest exposure tier, smallest allocation.

- Tiered Wallet Architecture — asset allocation by storage tier with security controls at each layer

Source: Halborn

Key management technologies: MPC versus multi-signature

Two primary approaches dominate institutional key management. These are multi-signature (multi-sig) schemes and multi-party computation (MPC).

Multi-signature requires multiple distinct private keys to authorize a transaction, with the policy often enforced on-chain. While transparent and well tested on certain blockchains, multi-sig introduces operational rigidity. Changes to signing thresholds or participants typically require on-chain transactions and the model can create fragmentation across different networks.

Multi-party computation, by contrast, has become the preferred standard for institutional custody. MPC cryptographically splits a private key into shares distributed across multiple parties or locations and transactions are signed collaboratively without ever reconstructing the full private key. This delivers several advantages for banks, including greater flexibility to adjust policies without on-chain changes, improved resilience against single-point compromises, and consistent operation across multiple blockchains. MPC also reduces the gas costs associated with multi-sig verification on certain networks.

The choice between these technologies ultimately depends on the bank's regulatory requirements, operational maturity, and asset mix. In practice, many qualified custodians combine both approaches within a hybrid framework.

Aspect	Multi-Signature	Multi-Party Computation (MPC)	Institutional Preference
Key Reconstruction	Full key never needed	Full key never exists	MPC
Policy Changes	Often requires on-chain transactions	Off-chain, highly flexible	MPC
Cross-Chain Support	Chain-specific limitations	Consistent across networks	MPC
Operational Overhead	Moderate	Higher initial setup, lower ongoing costs	MPC for scale

- MPC vs. Multi-Signature: Institutional Tradeoffs

Hardware Security Modules (HSMs) and supporting controls

Hardware Security Modules remain a cornerstone of high-assurance custody. These tamper-resistant devices generate, store, and manage cryptographic keys within a hardened boundary that prevents extraction even if the device is physically compromised. Leading institutional solutions use HSMs validated to FIPS 140-3 Level 3 or higher (with FIPS 140-2 Level 3 devices still in service during the transition period), often in combination with MPC for layered protection.

Beyond core technologies, disciplined custody requires equally disciplined supporting processes. Key generation should be performed through formal ceremonies in secure, audited environments with multiple independent witnesses and video recording. Keys or key shares should be rotated on a scheduled basis according to risk-based policies, without disrupting client operations. In addition, disaster recovery protocols should combine secure backup mechanisms with geographic distribution of key shares and tested recovery procedures that meet defined Recovery Time Objectives (RTO) and Recovery Point Objectives (RPO).

Integration with Fuze Finance operating models

In the white-label model, Fuze Finance connects to regulated custodians that employ these institutional-grade controls, allowing banks to offer qualified custody without building the infrastructure internally. In the fully disclosed model, the same technical architecture is documented transparently with clients and regulators. In both cases, client assets remain fully segregated, with clear proof-of-reserves reporting available.

By applying these proven technical controls, banks can achieve the security standards expected by regulators and sophisticated clients while maintaining operational efficiency. Halborn recommends that every custody arrangement undergo independent architectural review and regular penetration testing focused specifically on key management pathways and wallet infrastructure.

CASE STUDY

Validator Key Centralization: The Ronin Network Breach, March 2022: $624 Million

A custody provider that lost funds due to inadequate key management: what the architecture should have looked like

In March 2022, the Ronin Network, the blockchain bridge underpinning one of the world's largest blockchain gaming ecosystems, was drained of approximately 173,600 ETH and 25.5 million USDC, a total of $624 million at prevailing prices. The root cause was not a smart contract vulnerability. It was a key management architecture that created a false impression of distributed control while concentrating decisive signing authority in a single entity.

The architecture that failed

Ronin used nine validator nodes, requiring five-of-nine signatures to authorize bridge transactions. Four of the nine validators were operated by the network's developer. A fifth validator, all that was needed to reach the approval threshold, had been temporarily delegated to that same developer nine months earlier under a governance agreement with a partner DAO, to reduce transaction processing load. The delegation was never formally revoked. At the time of the attack, one entity effectively controlled five of nine validators. The architecture appeared distributed. It was not.

How the keys were compromised

The Lazarus Group initiated access via social engineering: a fake job offer PDF delivered to an employee installed malware providing a foothold on internal systems. Lateral movement across the network gave the attacker access to the four developer-controlled validator keys. The fifth validator signature was obtained through a gas-free RPC node that had been used to facilitate the earlier governance delegation and remained accessible. The private keys were not stored in hardware security modules. The breach went undetected for six days.

What the architecture should have looked like

True organizational and geographic independence across all validator operators, with no single entity able to approach signing threshold control under any operational arrangement. Hardware security module (HSM) storage for all validator private keys, with keys never residing on networked machines accessible to operational systems. Regular audits of key permissions and delegations to ensure no temporary grants persist beyond their authorized scope. Formal revocation procedures with the same governance formality as key issuance. For banks evaluating digital asset bridge or custody infrastructure, Halborn identifies the Ronin case as emblematic of a broader pattern: governance decisions that affect key distribution are security-critical events. They must be treated as such, not resolved through operational shortcuts.

- Sources: Halborn, "Explained: The Ronin Hack (March 2022)". halborn.com.

Sound technical custody architecture is a necessary condition for institutional security — but it is not sufficient. The controls described in Section 5b protect the private keys themselves. The controls that follow address the operational environment around those keys: the people, processes, and governance structures that determine whether strong technical architecture actually holds under real-world pressure.

06

Operational Security & Internal Controls

Operational security represents the day-to-day discipline that translates strong technical controls into sustained institutional resilience. Even with a well-designed custody architecture, gaps in processes or human oversight can create exploitable weaknesses. Banks and custodians must therefore establish layered internal controls that address governance, human factors, process integrity, and continuous oversight.

Segregation of duties and governance framework

Clear separation of responsibilities forms the cornerstone of operational security. Trading and front-office teams must have no direct access to custody signing systems, while custody and treasury operations teams should not initiate or approve client trades. This division prevents any single role from controlling the full transaction lifecycle. Leading institutions strengthen this further through a formal three-lines-of-defense model, in which business operations form the first line, risk and compliance oversight the second, and independent internal audit the third. This governance structure ensures objective review of digital asset activities and aligns with the traditional banking standards that regulators expect to see extended into crypto operations.

Transaction approval workflows and policy engines

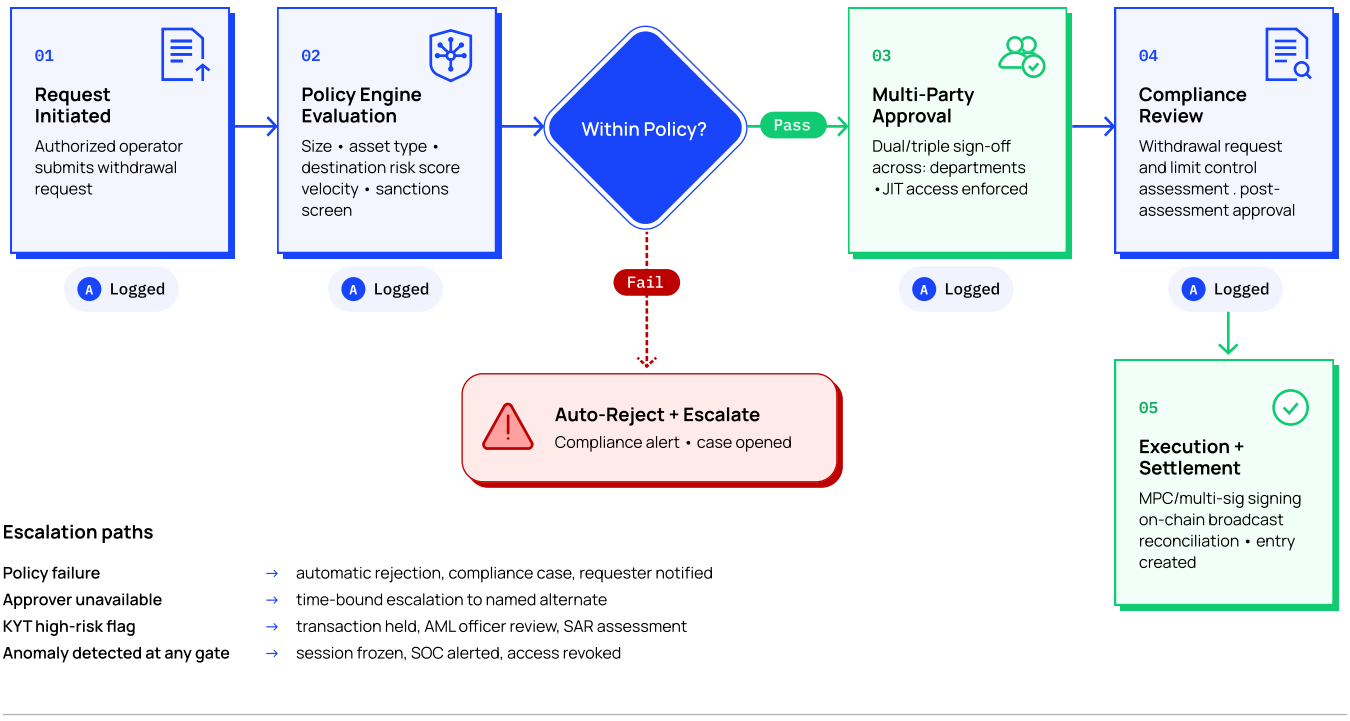
Configurable policy engines enforce multi-level approval workflows tailored to institutional risk appetite. These systems evaluate transactions dynamically based on parameters such as size, asset type, client segment, destination address risk score, geographic factors, or time-based rules. High-value withdrawals, for instance, typically require dual or triple approvals across departments together with real-time compliance review. Policy engines also embed automated pre-trade controls, including position limits, velocity checks, and sanctions screening, ensuring every action complies with both internal policies and regulatory obligations.

Privileged access management for internal staff

Access to custody platforms, administrative consoles, and key management systems requires rigorous privileged access management. Institutions should apply the principle of least privilege, time-bound just-in-time access and mandatory approval workflows for elevated rights. All privileged actions must produce immutable audit logs capturing the user, the action, the timestamp, and the business justification. Effective implementations combine hardware-backed authentication, behavioral analytics, session recording, and automated revocation to detect and respond to anomalous administrator behavior in real time.

High-Value Withdrawal: Approval Workflow

Control gates, audit logging points, and escalation paths from request to execution



- High-Value Withdrawal: Approval Workflow — control gates, audit logging points, and escalation paths from request to execution

24/7 monitoring, anomaly detection, and alerting

Digital asset markets operate continuously, and institutions therefore require always-on security operations that include real-time monitoring of wallet movements, API interactions, and administrative actions. AI-driven behavioral analytics establish baselines for normal activity and flag deviations such as unusual access patterns, rapid transaction velocity changes, or anomalous geographic logins. Alerts must follow defined escalation matrices with clear on-call responsibilities. Integration with enterprise Security Information and Event Management (SIEM) platforms provides centralized visibility and supports forensic investigation when needed.

Insider threat mitigation specific to digital asset teams

The high value concentrated in digital asset operations warrants dedicated insider threat programs. These typically combine enhanced background screening, continuous monitoring of privileged users, mandatory periodic vacations for key roles, and behavioral analytics focused on indicators specific to crypto operations. Regular, role-specific security awareness training covering phishing, social engineering, and the risks unique to digital assets further reinforces the human layer of defense.

Independent review, audit, and resilience controls

Beyond day-to-day operations, banks should implement regular independent audits of their digital asset controls. This includes periodic penetration testing, architecture reviews, and alignment with established frameworks such as the NIST Cybersecurity Framework and the EU's Digital Operational Resilience Act (DORA), dependent on the applicable jurisdiction. Many institutions also maintain insurance coverage specific to digital assets as an additional financial safeguard. Together, these measures provide objective assurance to regulators, clients, and internal stakeholders.

Integration with Fuze Finance operating models

In both white-label and fully disclosed models, Fuze Finance collaborates with regulated custody partners whose platforms embed these operational controls by design. Banks receive direct API access to audit logs, monitoring dashboards, and compliance reports, which enables them to maintain strong internal oversight and meet regulatory expectations for operational resilience without developing a complete security operations capability in-house from the outset.

Taken together, these operational security and internal control measures create overlapping layers of protection. They ensure that technical safeguards are reinforced by disciplined governance, vigilant monitoring, and independent verification, delivering the institutional-grade resilience that sophisticated clients and regulators require.

CASE STUDY

Retained Developer Access: The Infini Hack, February 2025: $50 Million

An insider threat incident at a crypto firm and the controls that could have prevented it

In February 2025, a DeFi neobank lost $50 million to an attacker who had previously been an authorized member of its own development team. The Infini hack is the clearest documented example of how inadequate offboarding and access management controls create an insider threat that persists long after the relevant individual has left the organization.

What happened

A former developer who had worked on the protocol's smart contracts retained a privileged administrative role after their engagement ended. This role, embedded in an unaudited, unverified smart contract, held the ability to drain the protocol's vault. The former developer used their knowledge of the contract's structure and their retained key to execute the drain directly. The contract had never been subjected to external security review, so the privileged role had never been identified, disclosed, or subjected to governance controls. The protocol had no mechanism to detect that a former team member still held an active administrative key.

The controls that were absent

Halborn's analysis identified three preventable failure points. First, the privileged role was controlled by a single key with no multisignature requirement: one individual with one key was sufficient to drain the vault. A multisig arrangement would have required compromise of multiple independent keyholders. Second, the smart contract had not been audited or externally verified: security review would have identified the elevated role and flagged its single-key design as unacceptable for a production contract holding client funds. Third, there was no formal developer offboarding procedure that included key rotation and role revocation. Privileged access granted during development was never removed after launch.

What the controls should look like

All privileged protocol roles, particularly those capable of moving or minting assets, must be held by multisig wallets with independent keyholders, not individual developer accounts. Developer access must be explicitly revoked and keys rotated as a required step in any offboarding procedure. Smart contracts holding material funds must be audited before deployment, with particular attention to elevated roles and their governance. For banks deploying digital asset infrastructure or onboarding partners who run smart contract infrastructure, Halborn recommends a privilege inventory review before go-live: every key that can affect client assets must be identified, its holder verified, and a rotation and revocation schedule defined.

- Sources: Halborn, "Explained: The Infini Hack (February 2025)"; "Operational Risks: A Leading Crypto Threat in 2025". halborn.com.

Operational controls and internal governance address the human and process dimensions of institutional security. A third layer of risk, specific to digital assets and without direct equivalent in traditional banking, sits at the protocol level: the smart contracts and on-chain logic that govern how assets move. Banks expanding beyond straightforward buy-and-hold products into tokenized assets, on-chain settlement, or DeFi-adjacent instruments must assess this risk with the same rigor applied to custody and operational controls.

07

Smart Contract & Protocol Risk

Beyond custody and operational controls, banks face material risks when interacting with smart contracts, tokenized assets, or decentralized protocols. These components introduce code-level vulnerabilities that can lead to rapid, irreversible losses even when core infrastructure remains secure. A robust approach to protocol due diligence and ongoing risk management is therefore essential.

Due diligence before integrating any DeFi protocol or tokenized asset

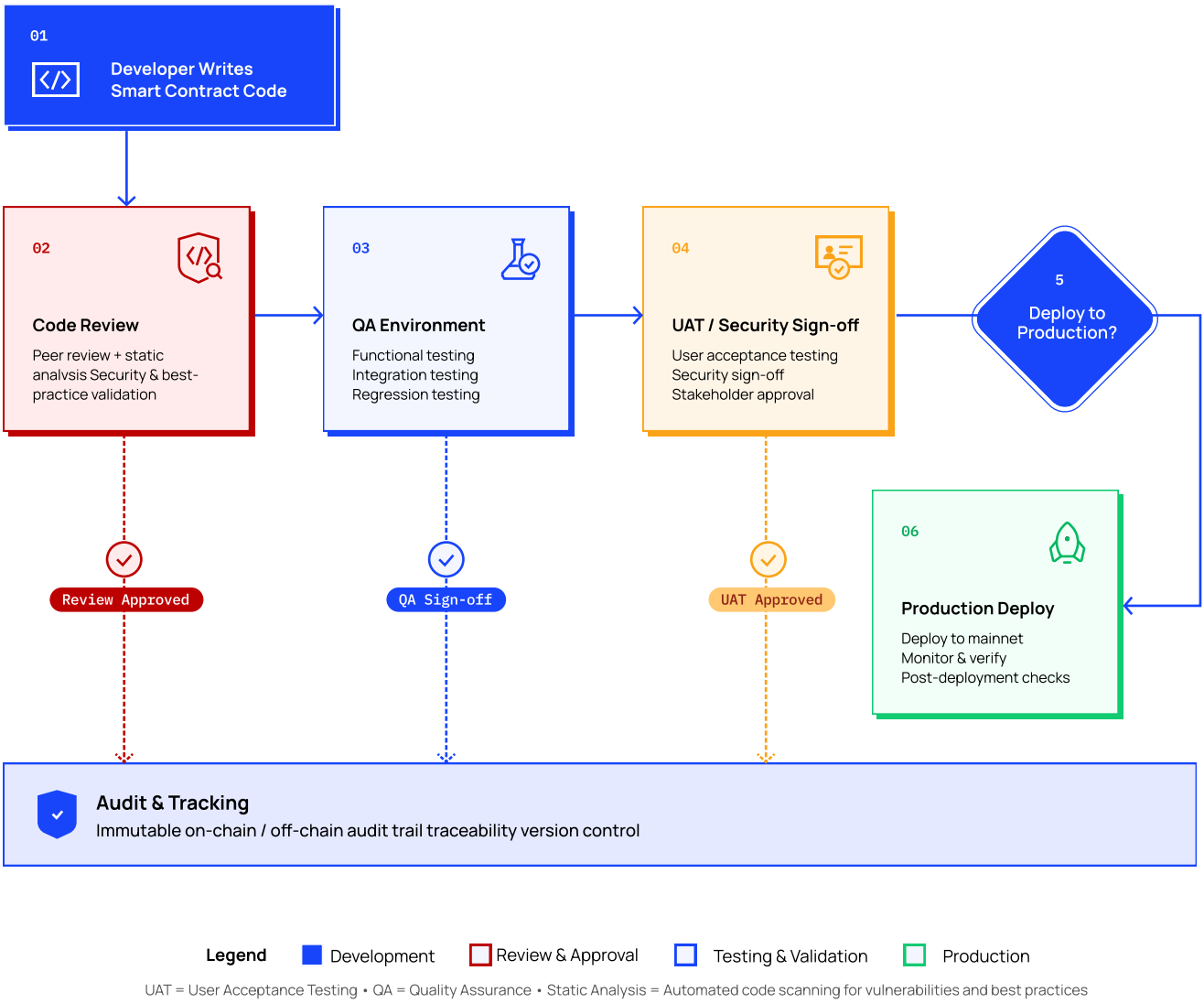
Every new asset, protocol, or smart contract must undergo structured evaluation before activation. This process includes:

- Comprehensive smart contract audits by reputable firms covering business logic, access controls, economic incentives, and mathematical soundness
- Review of the development team's background, audit history, and incident track record
- Assessment of on-chain governance mechanisms, upgradeability features, and administrative privileges
- Analysis of liquidity depth, oracle dependencies, and potential systemic correlations with other supported assets

Only assets and protocols that meet predefined risk thresholds should receive approval. This front-loaded diligence reduces exposure to projects with hidden weaknesses or unproven security postures before any client funds are at risk.

Smart Contract Deployment & Change

Secure, controlled, and auditable lifecycle for code changes



- Smart Contract Deployment & Change — secure, controlled, and auditable lifecycle for code changes

What a smart contract audit covers and what it does not

A high-quality smart contract audit examines source code for common vulnerabilities such as reentrancy, unauthorized access, improper error handling, and integer overflows, the last of which remains particularly relevant in older contracts or non-EVM environments. It also evaluates economic design and potential attack scenarios. However, audits provide point-in-time assurance only. They do not guarantee future security after code changes, nor do they cover off-chain components, oracle reliability, or human operational errors. Institutions must therefore treat audits as one control within a broader risk framework rather than as a complete security endorsement.

Beyond code-level vulnerability review, institutions should require economic and incentive design auditing as a distinct workstream. Many of the largest DeFi exploits, including oracle price manipulation, governance attacks, and liquidity drain scenarios, are not code bugs in the traditional sense. They are rational actors exploiting incentive structures that function exactly as written. Economic audits model these adversarial behaviors, stress-test tokenomics and collateralization assumptions, and evaluate whether protocol governance can be captured or manipulated at scale. Separately, formal verification, which uses mathematical proofs to confirm that a contract's behavior matches its specification under all possible inputs, is emerging as a complementary control for high-value or high-complexity contracts, and leading custodians are beginning to require it for critical infrastructure. Neither replaces a standard audit. Institutions that rely on audit alone, however, are evaluating only whether the code is correct, not whether the system is safe.

Ongoing monitoring post-audit

Security does not end at deployment. Banks and their infrastructure partners should maintain continuous oversight through:

- Real-time monitoring of contract interactions and on-chain events
- Subscription to threat intelligence feeds and automated exploit detection tools
- Periodic re-audits following any material code upgrades or parameter changes
- Clear incident response playbooks that define containment, client communication, and asset recovery procedures in the event of a protocol exploit

This sustained vigilance enables early detection and rapid response to emerging threats.

Integration with Fuze Finance operating models

Fuze Finance maintains a curated list of supported assets and protocols that have passed rigorous legal, compliance, and security reviews. In both white-label and fully disclosed models, the infrastructure applies these risk controls automatically before any transaction executes. Banks benefit from this pre-vetted environment while retaining the ability to request additional due diligence on specific assets through dedicated channels.

By embedding these smart contract and protocol risk practices into the operational framework, banks can confidently expand their digital asset offerings while maintaining the security and regulatory standards expected in institutional finance.

Halborn's experience assessing digital asset infrastructure across institutions suggests that the most successful programs treat security as an architectural principle rather than a compliance exercise. Operating models, custody arrangements, trading infrastructure, and third-party relationships all create distinct attack surfaces that must be assessed together. Institutions that embed independent security validation into every stage of the lifecycle are better positioned to scale safely while maintaining the trust of regulators, counterparties, and clients.

CASE STUDY

Integer Overflow in a DeFi AMM: The Cetus Protocol Hack, May 2025: $223 Million

A protocol exploit that affected an institutional counterparty: timeline, impact, and lessons

In May 2025, Cetus Protocol, the largest decentralized exchange on the Sui blockchain, was exploited for approximately $223 million through a single mathematical error in its liquidity calculation logic. The incident illustrates the limits of smart contract auditing and the potential impact on institutional counterparties when DeFi infrastructure fails at the arithmetic level.

The vulnerability

Cetus's liquidity contracts included a function called checked_shlw, designed to prevent integer overflow when shifting values left by a 64-bit word. The function compared an input value against a threshold constant. The constant used in the implementation was incorrect: the code compared against 0xFFFFFFFFFFFFFFFF shifted left 192 bits, the maximum possible value, rather than the operationally correct bound of 0x1 shifted left 192 bits. The result was an overflow check that would only reject inputs exceeding the absolute maximum, permitting many overflow-causing values to pass through unchallenged. The Move programming language intentionally permits bit shifts to produce overflows (unlike standard arithmetic operations, which are protected by the runtime), making this specific check load-bearing for the protocol's security. With it broken, the overflow protection was absent in practice.

The attack

The attacker initiated a flash loan, opened a liquidity position in Cetus with an artificially narrow tick range, then submitted a liquidity value that passed the flawed overflow check but triggered an overflow during the token deposit calculation. The overflow caused the required deposit to be calculated as one token. The attacker deposited one token and was assigned the full pre-overflow liquidity amount. That liquidity position was then used to drain protocol pools across multiple assets. Halborn's analysis of the Cetus hack identified that a single incorrect constant in one function was sufficient to undermine the entire overflow protection layer and expose $223 million in liquidity.

Timeline and recovery

The exploit occurred on 22 May 2025. Cetus paused the protocol within hours. Approximately $162 million of the stolen funds were frozen through coordinated action by Sui validators; approximately $61 million remained unrecovered. The incident triggered immediate liquidity withdrawal across the Sui DeFi ecosystem and raised material questions about the adequacy of Move ecosystem tooling for detecting arithmetic edge cases at audit.

Lessons for institutions:

Halborn's analysis makes clear that a clean audit report does not eliminate smart contract risk, it defines the boundary of the review conducted at a point in time. Mathematical edge cases in liquidity and pricing logic require specialist review that goes beyond standard vulnerability identification: invariant testing, formal verification of arithmetic bounds, and proof-of-concept exploit development against the specific parameters of deployed contracts. For banks and custodians integrating DeFi protocols, or conducting due diligence on counterparties that do, Halborn recommends verifying audit scope against the specific functions handling asset flows, reviewing change management post-audit, and establishing ongoing on-chain monitoring for anomalous transaction patterns, rather than reliance on an audit certificate alone.

- Sources: Halborn, "Explained: The Cetus Hack (May 2025)"; "Year in Review: The Biggest DeFi Hacks of 2025". halborn.com.

The security architecture described in Sections 5 through 7 — custody design, operational controls, and smart contract risk management — does not exist in isolation from regulatory requirements. Increasingly, it is the mechanism through which regulatory compliance is demonstrated. The sections below address the regulatory landscape banks must navigate, and how a security-first approach provides the evidentiary foundation that regulators are looking for.

08

Regulatory Alignment by Design

8a. The Regulatory Landscape for Banks

The regulatory treatment of digital asset services for banks is not uniform globally, and treating all jurisdictions as equivalent is a compliance error with real consequences. The frameworks differ in what they regulate, who they regulate, and what permissions they grant.

European Union, MiCA (full CASP application)

MiCA is the most comprehensive crypto-specific legislative framework currently in operation. It applies across all 27 EU member states and, under EEA extension, to Iceland, Liechtenstein, and Norway. MiCA requires any entity providing crypto-asset services to EU clients to be authorized as a Crypto-Asset Service Provider (CASP) by the national competent authority of an EU member state. A CASP authorization grants EU-wide passporting rights, enabling cross-border service provision without separate national licenses.

MiCA's CASP regime covers: custody and administration of crypto-assets, operation of trading platforms, exchange services (crypto-to-fiat and crypto-to-crypto), execution of orders, reception and transmission of orders, portfolio management, and advisory services. Capital requirements are tiered: EUR 50,000 for advisory services, EUR 125,000 for custody and exchange services, and EUR 150,000 for trading platforms. The first CASP authorizations were issued in the Netherlands and Malta on 30 December 2024

What MiCA does not cover: crypto-assets that qualify as financial instruments under MiFID II (those remain under MiFID II); fully decentralized services with no identifiable intermediary; and NFTs, with limited exceptions. Banks that are already authorized credit institutions under EU banking law can provide many CASP services without a separate MiCA authorization, but must notify their national competent authority.

Model implications: in the fully disclosed model, the distributing bank must hold its own CASP authorization for the services it provides to EU clients. The infrastructure provider's authorization does not transfer. This applies equally in the white-label model: the bank distributes under its own brand and holds the client relationship; the bank's own authorization governs what it can offer.

Switzerland, AMLA (SRO pathway)

Switzerland is not an EU or EEA member and is not subject to MiCA. Switzerland operates under the Federal Act on Combating Money Laundering and Terrorist Financing (AMLA, SR 955.0). Financial intermediaries, including payment service providers and digital asset brokers operating on an agency basis, are required to affiliate with a FINMA-recognized Self-Regulatory Organization (SRO) under Article 14 AMLA.

SO-FIT (Organisme de surveillance pour intermediaires financiers et trustees) is one of FINMA's recognized SROs with specific expertise in fintech, digital asset, and payment service intermediaries. SO-FIT membership authorizes the member to operate as a financial intermediary in Switzerland, with ongoing obligations covering AML/CFT compliance, annual AML audits by an approved auditor, and adherence to SO-FIT's directives and regulations.

What SO-FIT/AMLA regulates: AML/CFT obligations, client due diligence, transaction monitoring, record-keeping, and suspicious activity reporting to MROS (Switzerland's financial intelligence unit).

What it does not regulate: investment advice, portfolio management, or licensed banking activities. A financial intermediary under AMLA cannot accept public deposits, manage collective investment schemes, or issue securities: those activities require separate FINMA authorizations under BankG, CISA, or FinIA respectively.

Switzerland's FinSA (Financial Services Act) sets conduct and disclosure standards for financial service providers. FinIA establishes licensing categories for asset managers and fund managers. The FMIA instead governs DLT trading facilities. Banks and infrastructure providers operating in Switzerland need to map their specific activities to the correct regulatory instrument rather than assuming a single authorization covers everything.

United States, OCC, Federal Reserve, and state frameworks:

The US does not have a single unified federal crypto framework comparable to MiCA. Regulation is distributed across federal banking regulators (OCC, Federal Reserve, FDIC), the SEC, the CFTC, and state-level money transmission regimes.

For banks specifically, the OCC has progressively clarified permissible digital asset activities through a series of interpretive letters. The current position as of 2025-2026:

- National banks and federal savings associations may provide crypto asset custody services, including safeguarding private keys
- Banks may hold deposits as reserves backing stablecoins in certain circumstances
- Banks may participate in distributed ledger networks for payment verification and certain stablecoin activities
- Custody, stablecoin activities, and node verification confirmed as permissible
- The prior requirement that banks seek supervisory non-objection before engaging in crypto activities has been rescinded by the OCC, Federal Reserve, and FDIC
- Banks may execute buy and sell orders for assets held in custody at the client's direction and may outsource these activities to third parties subject to appropriate risk management
- Banks may hold limited amounts of crypto assets as principal for network fee payment and platform testing

However, the OCC guidance does not clarify securities classification of specific tokens (that remains with the SEC) and state money transmission licensing requirements for activities not conducted through a nationally chartered bank. Stablecoin issuance at the federal level is now addressed by the GENIUS Act, signed into law on 18 July 2025, which establishes the first federal regulatory framework for payment stablecoins.

UAE, VARA (Dubai), FSRA (Abu Dhabi), CMA and CBUAE (federal)

VARA (Virtual Assets Regulatory Authority) is the dedicated regulator for VASPs operating in Dubai, covering Dubai mainland and free zones excluding the Dubai International Financial Centre (DIFC). VARA's licensing categories cover: Virtual Asset Issuance, Transfer and Settlement Services, VA advisory services, VA broker-dealer services, VA custody services, VA exchange services, VA lending and borrowing, VA payments and remittances, and VA management and investment services. Each activity category requires a separate authorization and may be subject to additional conditions depending on the applicant VASP and the cumulative authorizations requested.

A similar digital asset framework has been released by the Financial Services Regulatory Authority (FSRA) of the Abu Dhabi Global Market (ADGM), governing the issuance, trading, and custody of digital assets for VASPs operating in Abu Dhabi. The FSRA's framework is one of the world's most progressive, regulating exchanges, custodians, and broker-dealers while enforcing strict rules on AML/CFT, consumer protection, market abuse, and technology governance.

The federal layer is separate.

The UAE Capital Market Authority (CMA) recently released a new digital asset framework (January 2026), encompassing eight licensed activities, new capital thresholds, strengthened governance standards, and a transition timeline which has already entered into force. What the CMA has built is an architecture that is internationally aligned to the design of the UK's FCA, MAS in Singapore, and the EU's MiCA framework and main digital asset provisions.

At the same time, the UAE Central Bank (CBUAE) regulates payment services at federal level, including those involving digital assets used as payment instruments, and regulates stablecoin issuance in relation to AED-referenced tokens. The DIFC and ADGM each have their own regulatory frameworks (DFSA and FSRA respectively); VARA does not apply within those zones.

This multi-regulator structure means a firm operating across Dubai mainland and a DIFC entity, or providing both payment and custody services, may need authorizations from multiple regulators simultaneously. The Fuze Finance holds a VARA Broker-Dealer license (through Morpheus Software Technology FZE) and CBUAE payment licensing (Niobe Payment Services, RPSCS Category III) as distinct regulated entities, reflecting this multi-layer structure and flexibility in deploying use cases.

How model choice affects regulatory obligations

The fully disclosed model places the following activities on the bank: client-level regulatory obligations, suitability assessment (where applicable), AML/CFT controls, client relationship, and reporting. In the Swiss AMLA context, the bank delivering services to end clients must be a FINMA-regulated institution or SRO member. Fuze Finance operating as the infrastructure provider beneath the bank does not remove those obligations from the bank.

The regulatory framework a bank operates under defines what it must demonstrate to its regulator. The security architecture it deploys determines whether it can demonstrate it. The mapping below shows how the institutional security controls described throughout this paper satisfy specific regulatory obligations — and why the two cannot be designed independently.

8b. Mapping Security Controls to Regulatory Requirements

Security architecture must do more than protect assets. It must also demonstrably satisfy the growing body of regulatory expectations placed on banks and custodians offering digital asset services. Regulators increasingly expect institutions to integrate security controls directly into their compliance and operational resilience frameworks.

How a security-first architecture satisfies audit, reporting, and resilience mandates

Modern institutional security programs align naturally with core regulatory requirements through several mechanisms:

- **Immutable audit trails:** Every critical action, including key generation, policy changes, transaction approvals, wallet movements, and administrative access, is logged in a tamper-evident, time-stamped manner. These logs support regulatory reporting obligations, internal audits, and forensic investigations while providing verifiable evidence of control effectiveness.

- **Evidence preservation and demonstrable controls:** Defense-in-depth architectures combining MPC or multi-sig custody, privileged access management, real-time monitoring, and policy engines produce continuous evidence that institutions can present during supervisory reviews or external audits.

- **Incident response and notification readiness.** Formal playbooks with defined timelines for internal escalation and regulatory reporting enable banks to meet the strict notification windows required under frameworks such as DORA in the EU.

DORA implications for crypto infrastructure

The EU's Digital Operational Resilience Act places specific obligations on financial entities regarding ICT risk management, incident reporting, and third-party oversight. For digital asset operations, this translates into concrete requirements:

- Comprehensive testing of critical systems through threat-led penetration testing and red-team exercises at least annually
- Strong business continuity and disaster recovery plans with clearly defined Recovery Time Objectives (RTO) and Recovery Point Objectives (RPO)
- Rigorous oversight of critical third-party providers, including custody platforms and infrastructure partners, with contractual rights to audit and obtain evidence of their security controls

Fuze Finance's infrastructure partners maintain DORA-aligned documentation and testing regimes, which banks can use directly in their own regulatory filings and oversight programs.

Alignment with broader regulatory expectations

Beyond DORA, strong security controls support compliance across major jurisdictions:

- In Switzerland, they reinforce SO-FIT/AMLA obligations for sound risk management and client asset protection
- In the UAE under VARA, they help demonstrate the governance and technology standards required for licensed activities
- In the United States, they align with OCC expectations for safe and sound banking practices in crypto custody and execution

Regulators consistently emphasize that security has moved from merely being a technical identifier into becoming a core component of operational resilience and consumer protection.

Regulatory Area	Key Security Controls	Evidence Produced	Primary Benefit
Audit & Reporting	Immutable logs, policy engines	Tamper-evident records	Supervisory review readiness
Operational Resilience (DORA)	Red-team testing, BCP/DR plans	Test reports, RTO/RPO metrics	Incident preparedness
Third-Party Risk	Vendor audits, MPC custody, monitoring	Due diligence reports, SLA evidence	Vendor oversight
Client Asset Protection	Segregation, cold storage, proof-of-reserves	Periodic attestation reports	Regulatory compliance & trust

Security Controls vs. Regulatory Requirements Mapping Matrix

Integration with Fuze Finance operating models

In both the white-label and fully disclosed models, Fuze Finance and its custody partners operate security architectures that are purpose-built for regulatory alignment. Banks receive the necessary reports, audit logs, and evidence packages to fulfill their own obligations while benefiting from institutional-grade controls that would be costly and time-consuming to build independently.

Indeed, Fuze Finance can provide banks with audit trails, evidence preservation reports, and perform incident reporting obligations on behalf of financial institutions.

A security-first approach, therefore, provides the practical foundation that enables banks to meet and exceed supervisory expectations while confidently scaling their digital asset services.

CASE STUDY

Security Controls Mapped to Regulatory Obligations: Halborn's Work with Regulated Financial Institutions

How Halborn's security assessments map directly to DORA, audit, and incident-reporting obligations

Two Halborn engagements with regulated financial institutions illustrate how a security-first architecture directly satisfies the audit, resilience, and incident-reporting mandates that regulators are increasingly formalizing — and that DORA makes legally binding for EU-regulated entities from January 2025.

Engagement 1 — CBDC Pilot Infrastructure: Red Team Exercise + Regulatory Evidence Package. A major financial institution participating in a government-backed central bank digital currency pilot engaged Halborn to conduct a full-scope red team exercise across its blockchain and enterprise infrastructure before advancing to subsequent pilot phases. The institution operated Hyperledger Besu validator nodes within a nationally significant distributed ledger network, with regulatory counterparts and central bank partners requiring independent validation of its security posture.

Halborn's engagement covered four tracks simultaneously: adversarial red team simulation emulating real-world threat actors; infrastructure penetration testing of the Windows domain, Active Directory, and network devices integrated with blockchain operations; blockchain node security assessment of validator configurations, JSON-RPC interface exposure, and consensus integrity controls; and identity and access management review covering Kerberos authentication, password policies, and privilege escalation paths.

The assessment identified 16 vulnerabilities, including 4 critical and 9 high-severity findings. Among the most significant: unauthenticated access to administrative blockchain APIs that could have allowed an external actor to inject or remove peers from the consensus network, and critical credential weaknesses (including Kerberoastable service accounts and guessable passwords) that created lateral movement paths from the corporate domain into blockchain node management interfaces. The cross-domain attack chain, compromised Active Directory credentials providing access to shared folders containing validator private keys, would have been invisible to assessors examining either layer in isolation.

The deliverable was a CVSS-scored findings report with a prioritized remediation roadmap, structured to provide the documentation needed to demonstrate operational resilience to regulators, central bank partners, and institutional counterparties. The red team exercise directly satisfied the threat-led penetration testing (TLPT) requirement under DORA Article 26, which mandates adversarial resilience testing for significant financial entities operating critical ICT infrastructure.

Engagement 2 — Multi-Jurisdictional Banking Institution: Security Architecture Aligned to Institutional-Grade Compliance. A large financial institution supporting coordination among banks and public-sector financial authorities engaged Halborn to support the security of an advanced distributed-ledger initiative spanning multiple jurisdictions and regulatory environments. Key challenges included key management for decentralized infrastructure (cryptographic key generation, storage, rotation, and usage across complex operational flows), smart contract and protocol risk review, and DevOps and CI/CD pipeline security.

Halborn delivered seven parallel assessment tracks: security architecture and data management review, key management assessment and recommendations, secure code review and smart contract security assessment, blockchain protocol security assessment including targeted penetration testing, code coverage and maintainability assessment, DevOps review covering CI/CD pipelines and incident-response procedures, and open-source technical risk and governance assessment. The DevOps review explicitly covered monitoring, logging, alerting, and incident-response collaboration: the three functions that regulators and DORA Article 17 require to be documented and tested as part of an ICT risk management framework.

The engagement produced a shared security posture across architecture, smart contract engineering, and operational teams, and aligned the platform with institutional-grade expectations ahead of production deployment. Recommendations addressed the root causes of systemic patterns (overly permissive configurations, inconsistent access controls, identity infrastructure not hardened for the elevated threat model) rather than individual vulnerabilities, providing durable evidence of control implementation for regulatory and counterparty review.

What these engagements demonstrate for banks entering digital asset markets:

Regulatory compliance in digital asset infrastructure is not satisfied by an audit report alone. DORA requires documented ICT risk management, regular threat-led testing, defined incident notification timelines, and third-party ICT risk controls, each of which corresponds directly to a security programme component. Halborn's approach treats the regulatory evidence package as a first-class deliverable, not a byproduct: CVSS-scored findings provide the documented risk register; red team exercises satisfy TLPT obligations; remediation roadmaps provide the improvement plan auditors require; and cross-layer assessments covering both blockchain and enterprise infrastructure reflect the integrated attack surface that regulators are increasingly scrutinizing.

- Sources: Halborn, "Case Study: Hardening Critical CBDC Pilot Infrastructure for a Major Financial Institution"; "Securing Next-Generation Financial Infrastructure for a Global Banking Institution"; "What Is the Digital Operational Resilience Act (DORA)?". halborn.com.

Regulatory alignment and security architecture converge most visibly in vendor and third-party risk management. A bank's security posture is only as strong as its weakest integration point — and in a digital asset infrastructure stack, the infrastructure provider, custody partners, and liquidity sources are all integration points that require the same standard of scrutiny the bank applies to its own operations.

09

Vendor & Third-Party Risk Management

Evaluating blockchain infrastructure and custody vendors

For a bank, a digital asset infrastructure partner is not a conventional software vendor. The relationship is structurally different in three ways that have direct implications for third-party risk management.

First, the infrastructure partner sits in the transaction flow. Unlike a SaaS tool that supports back-office functions, the infrastructure provider executes on behalf of the bank's clients. Failures, whether operational, security-related, or compliance-related, are visible to clients and to regulators in real time. The bank's reputational and regulatory exposure is directly linked to its infrastructure partner's performance.

Second, the infrastructure partner holds or routes client assets. Even in a non-custodial architecture, the infrastructure provider controls the execution layer through which client funds move. This requires the bank to apply the same standard of due diligence it would apply to any entity entrusted with client money, not simply the standard applied to a technology vendor.

Finally, the regulatory accountability for client-facing activity does not transfer. As outlined in Section 8, the bank remains the regulated entity responsible for its clients regardless of which infrastructure model it uses. Vendor failure does not excuse regulatory non-compliance. This means the bank needs to understand not only whether its vendor is capable, but whether the vendor's failure modes are within the bank's own risk tolerance and incident response capacity.

What banks should evaluate before selecting a digital asset infrastructure partner

- **Regulatory standing.** The vendor should hold applicable licenses or registrations in every jurisdiction where it operates as a principal in the transaction flow. Licenses should be verified directly with the relevant regulator, not accepted on the vendor's representation alone. The Fuze Finance, for instance, holds a VARA Broker-Dealer license (Morpheus Software Technology FZE) and CBUAE payment institution authorization (Niobe Payment Services, RPSCS Category III) as separate licensed entities, and obtained the SO-FIT affiliation for its Swiss entity - Fuze Finance (Switzerland) AG - to cover Swiss financial intermediary obligations. Therefore, each entity maps to a specific activity set.
- **Custody partner quality.** If the vendor does not self-custody but routes to third-party custody providers, the bank needs visibility into which custodians are used, what regulatory authorization those custodians hold, how client asset segregation is maintained, and what the custody provider's own security standards are. Fuze Finance provides incidental custody capabilities as part of its platform, enabling customers to access custody functionality where required as an ancillary component of the broader services provided by Fuze Finance.

  In addition, Fuze Finance offers flexibility to integrate, through its orchestration layer and single API, with leading global institutional custodians. This enables customers to leverage third-party institutional custody infrastructure without requiring separate integrations. A custody adapter is embedded at the platform level, allowing Fuze Finance to onboard and integrate additional custody providers as required, providing flexibility as customer requirements and the institutional custody landscape evolve.
- **Liquidity provider vetting.** The vendor's liquidity counterparties should themselves be regulated entities. Fuze Finance's Smart Order Router operates exclusively across licensed liquidity providers; counterparties are subject to ongoing due diligence and credit monitoring.
- **Operational resilience.** The vendor should demonstrate documented business continuity and disaster recovery procedures for its infrastructure, with defined recovery time objectives. In a 24/7 market with no settlement cutoffs, downtime has direct financial consequences for the bank's clients.
- **Audit and reporting.** The vendor should produce regular third-party security audits, provide an immutable audit trail of all platform events available for regulatory inspection, and be willing to engage directly with the bank's regulators as a disclosed technology provider where the regulatory framework requires it.
- **Contractual protections.** The bank should ensure its vendor contract addresses: data ownership and portability, incident notification timelines, indemnification for vendor-side failures, and orderly wind-down procedures that protect client assets if the relationship terminates.

Questions banks should ask to vendors:

- What regulatory authorizations do you hold, in which jurisdictions, and for which specific activities? Can you provide documentation directly from the regulator?
- Which custody providers do you connect to, and what is their regulatory status? How is client asset segregation maintained, and can you provide evidence of segregation on a regular basis?
- What is your process for adding or removing liquidity providers? How do you assess counterparty credit risk?
- Who are your banking partners for fiat settlement, and how are client funds held during the payment cycle?
- What third-party security audits have you completed in the last 12 months, and can you share the results (redacted if necessary) with our security team?
- What is your incident notification SLA to the bank in the event of a security event or operational failure? How have you handled such events in the past?
- How do you ensure continuity of service if a key personnel dependency is lost or a critical sub-vendor relationship ends?
- What is the exit process if the bank decides to terminate the relationship? How are client assets and data returned, and over what timeline?

Beyond the governance and regulatory dimensions of vendor selection, the technical integration itself requires dedicated security assessment. The API layer connecting a bank's core systems to its infrastructure partner is an active attack surface, not a passive conduit, and it must be evaluated accordingly.

API Security, Integration Risk, and Supply Chain Vulnerabilities in the Digital Asset Stack

API integrations represent a critical attack surface in any digital asset infrastructure partnership. Because the infrastructure provider sits directly in the transaction flow, weaknesses in API authentication, rate limiting, input validation, or session management can be exploited to trigger unauthorized trades, manipulate settlement instructions, or extract sensitive data.

Banks should therefore require their infrastructure partners to implement enterprise-grade API security controls, including mutual TLS authentication, strict IP allow-listing, request signing with HMAC or JWT, comprehensive rate limiting and throttling, and real-time API activity monitoring. All integration points must undergo regular penetration testing focused on business logic flaws and abuse cases specific to trading and settlement workflows.

Supply chain risk adds another layer of complexity. Many digital asset platforms rely on multiple open-source libraries, third-party custody SDKs, liquidity connectors, and analytics providers, and a vulnerability in any upstream dependency can cascade into the bank's environment. Halborn recommends that banks require Software Bill of Materials (SBOM) documentation, regular dependency vulnerability scanning, and contractual commitments for timely patching of critical components.

When these controls are properly implemented, the integration layer becomes a strength rather than a vulnerability. Fuze Finance's API architecture incorporates these security measures by design, providing banks with secure, auditable connectivity while minimizing integration risk.

With the threat landscape, infrastructure options, custody architecture, regulatory requirements, and vendor risk framework established, the question shifts from "what must be in place" to "where is a given institution today, and what does the path forward look like."

10

The Blueprint: A Maturity Model for Banks

The maturity model below provides that practical framework.

We propose a practical self-assessment framework for institutions at every stage of digital asset adoption:

Maturity Stage	Profile	Trading Model	Custody Model	Security Posture
Exploring	No live product	White-label	Third-party	Basic controls
Piloting	Limited rollout	White-label or hybrid	Third-party + monitoring	Formal audit program
Scaling	Full product suite	Hybrid or fully disclosed	Hybrid custody	SOC 2, pen testing
Optimized	Market leader	Fully disclosed	Self or qualified custody	Continuous monitoring + red team

Recommended self-assessment checklist for financial institutions:

Exploring stage: questions financial institutions should be able to answer before moving to Pilot

- Have you identified the regulatory authorization you need to offer digital asset services to your client base in each distribution jurisdiction?
- Have you defined the client segments you intend to serve (retail, HNWI, institutional, corporate) and the product scope (trading-only, trading + custody, staking, lending)?
- Have you completed initial due diligence on at least two infrastructure partners, including regulatory standing, custody arrangements, and security audit history?
- Have you assessed whether the white-label model (closed-loop, no external wallet connectivity) is the appropriate starting point given your current compliance maturity?
- Have you identified internal ownership for the digital asset product — a named accountable executive and a cross-functional team covering compliance, technology, and front-office?

Piloting stage: what should be in place before scaling

- Is your infrastructure integration documented end-to-end, including the data flows between your core banking system and the infrastructure provider's API?
- Have you completed at least one full transaction cycle, including client onboarding, KYC/AML screening, execution, settlement, and reporting, in a testing environment?
- Do you have documented incident response procedures for digital asset-specific scenarios: transaction failure, custody provider outage, and regulatory inquiry?
- Have you defined your margin structure and confirmed your pricing model against your infrastructure partner's wholesale fees?
- Have you completed a formal review of your AML transaction monitoring capability as applied to digital asset flows, including on-chain analytics coverage?

Scaling stage: infrastructure considerations

- Is your settlement infrastructure capable of handling 24/7 continuous processing without manual intervention?
- Do you have automated reconciliation between your core banking system and the infrastructure provider's settlement reports, for both fiat and digital asset legs?

- Have you reviewed whether closed-loop restrictions remain appropriate, or whether your client base and regulatory posture support activation of open-loop (external wallet) functionality?
- Is your reporting infrastructure capable of generating client-level transaction reports, cost basis records, and regulatory reports from the data your infrastructure provider supplies?
- Have you formally documented your infrastructure partner's role in your regulatory filings and risk management frameworks?

Optimized stage: indicators of a mature operating model

- The bank has evaluated whether components of the infrastructure stack should be internalized (custody integration, liquidity relationships, or reporting) as volumes justify the investment.
- The bank has formally reviewed its model choice, white-label vs. fully disclosed, against its current regulatory standing, client base, and compliance capability, and has documented the rationale for its current position.
- The bank participates in regulatory engagement on digital asset topics on behalf of its own client base, rather than relying solely on its infrastructure partner's regulatory relationships.

Recommended next steps at each stage:

- **Exploring:** Schedule a structured product review with a VASP's (e.g., Fuze Finance) partnership team covering operating model options, regulatory mapping for your specific jurisdictions, and a preliminary integration assessment. No infrastructure commitment is required at this stage.
- **Piloting:** Begin API integration in testing environment. Fuze Finance, for instance, provides a dedicated integration support team and a sandbox environment for full pre-launch validation. Target first live transaction within 90-120 days of integration commencement.
- **Scaling:** Review your transaction monitoring coverage and reconciliation automation with your partner VASP's compliance team. Assess whether closed-loop restrictions should be expanded. Establish a formal quarterly operating review between the bank's product and compliance teams and Fuze Finance's partner success team.
- **Optimized:** Engage enterprise partnerships team to review the long-term architecture, including whether elements of the stack should be internalized, whether the operating model should migrate from white-label to fully disclosed, and how the bank's regulatory strategy for digital assets should evolve.

The maturity model provides a framework for self-assessment. The recommendations that follow translate that assessment into action, addressing the specific decision-makers within a bank who will own different parts of this build, and the failure modes most commonly observed when institutions enter this market without adequate preparation.

11

Recommendations

CTOs: infrastructure decisions that are hard to reverse, get them right early:

The most consequential early decision is not which asset types to support or what the client interface will look like. It is the choice of infrastructure architecture and the custody model. These decisions have long downstream consequences.

Do not build what you can integrate. The internal build case for digital asset trading and settlement infrastructure is rarely justified at the volumes a bank will see in the first two to three years of a digital asset product. The engineering complexity, maintaining integrations with multiple liquidity providers, building and securing wallet infrastructure, operating a 24/7 settlement engine, and keeping pace with on-chain analytics and compliance tooling, consumes engineering capacity that is better deployed on client-facing differentiation. The infrastructure layer is not a source of competitive advantage for a bank; the client relationship and the bank's brand are. Build there; integrate everything else.

Choose an infrastructure partner with the regulatory standing to grow with you. An infrastructure provider that is only licensed in one jurisdiction, or that operates in a regulatory grey area, will become a constraint as you expand. Before signing, verify the partner's licenses and memberships directly with the relevant regulators, and confirm that their regulatory roadmap covers the markets you intend to serve in the next three years, not just today.

Plan your custody architecture before you launch, not after. Migrating client assets between custody solutions post-launch is operationally complex and requires client notification and, in some jurisdictions, regulatory approval. Decide upfront whether you will use a third-party custodian (the appropriate choice for most banks entering the market), how you will maintain proof of segregation, and how the custody arrangement will be disclosed to clients and regulators. Do not default to the lowest-cost custody option without evaluating the security and regulatory standards of the custodian.

Start closed-loop. The closed-loop operating mode, where client transactions stay within the bank's environment without external wallet connectivity, is the appropriate starting point for most banks. It materially reduces AML and fraud surface area, simplifies your compliance monitoring obligations, and is operationally more straightforward to audit. The decision to activate external wallet connectivity (open-loop) should be made explicitly, with a compliance review, not set as a default.

Build your reconciliation and reporting infrastructure in parallel with your trading infrastructure. The trading layer is typically what captures attention during a digital asset build. The reconciliation and reporting layer, ensuring every executed trade is reflected accurately in the bank's books, and that client-level reporting meets regulatory and conduct standards, is where operational failures occur. Both fiat and digital asset legs of every transaction need to reconcile against the infrastructure provider's records daily as a minimum.

Risk & Compliance Officers: how to pressure-test your vendor's security and compliance claims

Verify licenses independently. Do not accept a vendor's representation of its regulatory status. Look up the license or membership directly on the regulator's public register. For VARA licenses, check the VARA public register. For FINMA-recognized SRO memberships (SO-FIT), verify directly with SO-FIT. For CBUAE payment institution authorizations, verify on the CBUAE register. For MiCA CASP authorizations, check ESMA's register once it is fully populated, or the national competent authority's register.

Ask for the audit trail architecture, not just the audit report. A vendor that can show you a security audit report is meeting a minimum bar. A vendor that can demonstrate that every platform event generates an immutable log, including execution decisions, access events, and configuration changes, and can make that log available for your regulatory inspections, is meeting the standard required for institutional use.

Test the incident notification process before you go live. Document the vendor's incident notification SLA contractually. Then test it: run a simulated incident scenario and verify that notification timelines and escalation paths actually function as documented. Do not discover this process for the first time during a real event.

Ensure your AML monitoring covers on-chain analytics. Transaction monitoring for digital assets requires on-chain analytics (Know Your Transaction) in addition to the standard name screening and behavioral analytics applied in traditional banking. Verify that your infrastructure partner's compliance tooling includes real-time on-chain monitoring via an established analytics provider (Chainalysis and Elliptic are the market standard tools for institutional use), and that the outputs of that monitoring are integrated into your own AML reporting workflow, not siloed in the infrastructure provider's systems.

Confirm that client asset segregation is verifiable, not just asserted. The infrastructure provider should be able to produce periodic reports demonstrating that client assets are held in segregated accounts or wallets, separated from the provider's operational funds. This should be a contractual requirement, not an optional disclosure.

Common mistakes banks make when entering digital assets

Underestimating the compliance build. The trading infrastructure is typically the focus of a digital asset build, but the compliance infrastructure, transaction monitoring capable of handling on-chain analytics, AML officer training on digital asset typologies, and regulatory reporting templates, takes equally long to build and is more consequential when it fails.

Launching with an infrastructure partner that lacks appropriate regulatory authorization. The bank's own regulatory standing does not compensate for an infrastructure partner operating outside its authorized scope. Regulators examining a bank's digital asset operations will look at the entire stack, including the infrastructure partners and custody providers.

Treating the white-label model as a permanent solution without a roadmap. The white-label model is an appropriate starting point. It becomes a risk if the bank does not develop internal compliance capability alongside it, because the bank cannot remain permanently dependent on an infrastructure partner's compliance tools without understanding what those tools do and whether they meet the bank's own regulatory obligations.

Skipping reconciliation testing before launch. Failures in reconciliation between core banking systems and digital asset infrastructure typically surface as client reporting errors, which are regulatory events. This is one of the most common and most preventable sources of operational failure in a digital asset launch.

Opening with too broad an asset scope. Launching with many supported assets increases the compliance review burden (each asset needs to be assessed for securities classification and AML risk profile), the liquidity sourcing complexity, and the client risk disclosure requirements. A disciplined launch with a focused asset list, major assets with deep institutional liquidity, clear regulatory classification, and established on-chain analytics coverage, reduces execution risk materially.

12

Conclusion

The digital asset market has reached an institutional inflection point. Regulatory frameworks that were nascent three years ago are now fully operational. Client demand that was speculative is now documented and growing. The infrastructure required to serve that demand at a bank-grade standard exists and is accessible without an internal build program.

What remains is execution: the decision to enter the market, the choice of operating model, the selection of partners with the regulatory standing and security architecture to support institutional operations, and the discipline to build compliance and operational infrastructure alongside the client-facing product.

Fuze Finance's role in this is to provide the infrastructure layer, execution, settlement, compliance tooling, custody connectivity, and regulatory alignment, that allows a bank to launch a digital asset product on a defined timeline, at an institutional standard, without the cost and risk of internal development. The fully disclosed and white-label models that this paper has described are not theoretical constructs. They reflect how banks across Switzerland, the EU, the UAE, and beyond are entering this market today.

The choice of infrastructure partner, and the security architecture that partner operates, are not decisions to optimize for cost at the margin. They are decisions that determine whether a bank's digital asset offering is operationally resilient, regulatorily defensible, and commercially sustainable. Fuze Finance and Halborn have produced this framework to make that decision more informed, and the execution of it more reliable.

Appendices

Appendix A: Glossary of Key Terms

Smart Order Router (SOR): A routing engine that queries multiple liquidity providers simultaneously and selects the optimal execution strategy based on defined parameters including price, settlement terms, and counterparty reliability. Fuze Finance's SOR aggregates institutional liquidity across licensed venues, enabling best-execution outcomes without the bank managing individual LP relationships.

Fully Disclosed Model: A go-to-market structure in which the bank operates under its own brand with its role and the infrastructure provider's role both transparent to the end client. The bank holds the client relationship and all associated regulatory obligations.

White-Label Model: A go-to-market structure in which the infrastructure provider's technology stack operates beneath the bank's own brand. The end client interacts only with the bank's interface. The infrastructure provider's identity is not communicated to the end client in the standard flow.

Closed-Loop Operation: A transaction mode in which digital asset activity is contained within the bank's environment. External wallet transfers are not permitted. This is the standard starting configuration for banks launching on the white-label model.

Open-Loop Operation: A transaction mode in which clients can transfer digital assets to and from external wallets. Requires regulatory readiness for external wallet due diligence and enhanced AML monitoring.

VASP (Virtual Asset Service Provider, alternatively, also referred to as "CASP," i.e., Crypto Asset Service Provider.): An entity that provides virtual asset services, including exchange, transfer, custody, or financial services relating to virtual assets, as defined under FATF guidance and implemented in applicable national legislation including MiCA (EU), the AMLA framework (Switzerland), and VARA regulations (Dubai).

KYT (Know Your Transaction): On-chain analytics applied to virtual asset transactions to assess the risk profile of incoming and outgoing funds, identify exposure to sanctioned addresses, and detect patterns associated with illicit activity. Fuze Finance integrates KYT via Chainalysis.

SOR Best Execution: The obligation to achieve the best available outcome for a client transaction, taking into account price, costs, speed, and likelihood of execution. Fuze Finance's SOR logs all routing decisions and quote trails for audit and regulatory reporting purposes.

Atomic Settlement: A settlement mechanism in which both legs of a transaction, fiat and digital asset, settle simultaneously, eliminating the risk that one leg completes before the other.

SO-FIT (Organisme de surveillance pour intermédiaires financiers et trustees): A FINMA-recognized Self-Regulatory Organization (SRO) in Switzerland with specific expertise in fintech, digital asset, and payment service intermediaries. SO-FIT membership authorizes a financial intermediary to operate under the Swiss AMLA framework.

VARA (Virtual Assets Regulatory Authority): The dedicated regulator for virtual asset service providers operating in Dubai (mainland and most free zones, excluding DIFC). VARA issues licenses across eight activity categories and sets ongoing governance, AML/CFT, and market conduct standards.

MiCA (Markets in Crypto-Assets Regulation): The EU's comprehensive regulatory framework for crypto-asset services and issuers, in full effect across EU member states and EEA countries from 2025. Requires Crypto-Asset Service Provider (CASP) authorization for entities providing defined services to EU clients, with EU-wide passporting.

Appendix B: Security Audit Checklist for Banks

This checklist provides banks and custodians with a practical framework to evaluate the security posture of digital asset infrastructure providers and custody partners. It is designed to complement the vendor due diligence questionnaire in Appendix C.

1. Governance and Policy

- Formal information security policy approved by senior management and reviewed annually
- Defined security governance structure with clear roles and responsibilities
- Three-lines-of-defense model implemented and documented
- Alignment with recognized frameworks (NIST CSF, ISO 27001, DORA)

2. Custody and Key Management

- Tiered wallet architecture (cold / warm / hot) with documented asset allocation thresholds
- Use of MPC or multi-signature schemes with appropriate threshold policies
- Hardware Security Modules (HSM) validated to FIPS 140-3 Level 3 or higher
- Secure key generation ceremonies with multi-party witnessing and recording
- Key rotation and disaster recovery procedures tested at least annually

3. Operational Security & Controls

- Segregation of duties between trading, custody, and administration
- Multi-level transaction approval workflows with configurable policy engines
- Privileged access management with just-in-time access and session monitoring
- 24/7 Security Operations Center (SOC) or equivalent monitoring capability
- Insider threat program with behavioral analytics and mandatory controls

4. API and Integration Security

- Mutual TLS authentication and request signing for all bank-facing APIs
- Rate limiting, input validation, and business logic abuse protection
- Comprehensive API logging and real-time monitoring
- Regular penetration testing of integration endpoints

5. Smart Contract & Protocol Risk

- Mandatory smart contract audits by reputable firms for all supported protocols
- Ongoing monitoring and re-audit process for code changes
- Curated asset listing policy with documented risk assessment criteria

6. Resilience and Recovery

- Documented Business Continuity and Disaster Recovery plans
- Defined Recovery Time Objective (RTO) and Recovery Point Objective (RPO)
- Annual tabletop exercises and live failover testing
- Cyber insurance coverage specific to digital asset risks

7. Audit and Evidence

- Independent third-party security audits (penetration testing, architecture review) completed within the last 12 months
- Immutable audit logging of all critical events with long-term retention
- Ability to provide evidence packages to the bank's auditors and regulators
- SOC 2 Type II or equivalent attestation report available

8. Incident Response

- Formal incident response plan with defined regulatory notification timelines
- Tested ability to notify partners within contractual SLAs
- Post-incident review process with lessons-learned documentation

> **Recommended Usage:** Banks should request evidence or attestation for each item above during the due diligence phase. Halborn advises that critical items (marked as high-priority in a full engagement) receive independent validation through architecture reviews or penetration testing before production go-live.

Appendix C: Proposed Vendor Due Diligence Questionnaire

Section 1: Regulatory Standing

- List every regulatory license, authorization, registration, or SRO membership held by the vendor and each of its operating subsidiaries, specifying the issuing authority, license category, and the jurisdictions and activities covered.
- Provide the license or registration number for each authorization and confirm where it can be independently verified on the regulator's public register.
- Has the vendor been subject to any regulatory enforcement action, investigation, or material supervisory finding in the past three years? If yes, describe the matter and its resolution.
- What jurisdictions is the vendor currently applying to expand its regulatory footprint into, and on what timeline?

Section 2: Custody and Asset Segregation

- Does the vendor self-custody client digital assets, or does it route to third-party regulated custodians? If third-party, identify the custodians and their regulatory authorizations.
- How are client digital assets segregated from the vendor's own operating assets? Can the vendor provide periodic reports demonstrating segregation?
- What percentage of client assets are maintained in cold (offline) storage at any given time? What is the minimum threshold?
- What multi-signature or MPC authorization scheme governs wallet access and withdrawal authorization?
- How does the vendor maintain and report proof of reserves?

Section 3: Liquidity and Execution

- Identify the liquidity providers the vendor routes orders to. What due diligence does the vendor conduct on each LP, and how often is that due diligence refreshed?
- Describe the Smart Order Router's routing logic. On what parameters does it optimize, and how is the routing decision logged?
- How does the vendor demonstrate best execution to the bank and, where required, to the bank's regulators?
- What fiat settlement rails does the vendor support (SWIFT, SEPA, SIC, etc.) and through which banking partners?

Section 4: AML/CFT and Compliance Tooling

- What on-chain analytics provider does the vendor use for KYT (Know Your Transaction)? Is KYT applied to all virtual asset flows, or only to specific transaction types?
- How does the vendor screen for sanctions exposure and PEP risk at the transaction level?
- Describe the pre-trade risk controls available to the bank (position limits, transaction size limits, anomaly detection).
- What is the vendor's policy for listing and delisting supported assets? Who conducts the legal and compliance review, and what criteria are applied?
- How does the vendor support the bank's own AML reporting obligations? What data and reports are available via API, and on what frequency?

Section 5: Operational Resilience

- What is the vendor's documented RTO (Recovery Time Objective) and RPO (Recovery Point Objective) for its core transaction infrastructure?
- Describe the vendor's business continuity and disaster recovery testing regime. When was the last test conducted, and what were the findings?
- How does the vendor handle settlement failures — where a trade executes but settlement does not complete? What is the resolution process and timeline?
- What is the vendor's SLA for platform availability, and what compensation or remedies apply if SLAs are not met?

Section 6: Reporting and Audit

- What audit trail does the vendor maintain for all platform events? Is the log immutable, and is it available to the bank for regulatory inspection?
- What reports does the vendor generate for the bank, and at what frequency (end-of-day settlement reports, transaction-level data, compliance alerts)?
- Has the vendor completed a third-party financial audit in the past 12 months? Can it share the auditor's report or management letter (redacted if necessary)?
- What is the process for the vendor to provide information directly to the bank's regulator if requested?

Appendix D: Reference Architecture Diagrams: White-Label and Fully Disclosed

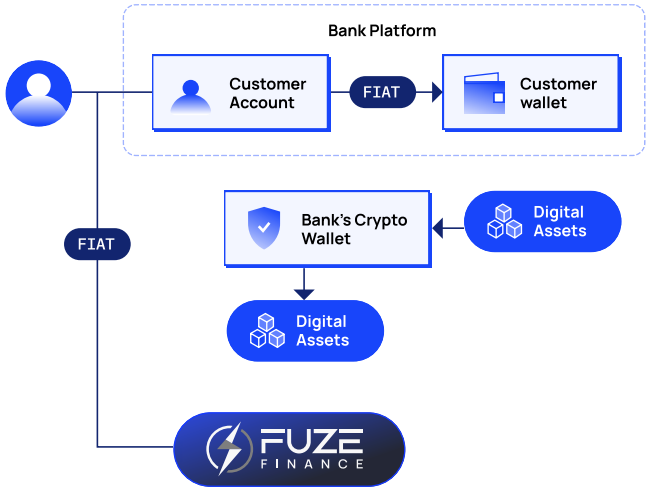
White-Label Architecture

The bank's client interacts exclusively with the bank's branded interface, mobile application, web portal, or private banking platform. The client sees no reference to Fuze Finance. Behind the interface, the bank's core banking system connects via Fuze Finance's API to the full Fuze Finance infrastructure stack: the Smart Order Router routes the order to the optimal licensed liquidity provider; execution is confirmed; the settlement engine processes both the fiat and digital asset legs atomically; KYT analytics are applied on-chain; and the settlement report is returned to the bank's reconciliation system. Client digital assets are held in segregated wallets through a regulated third-party custodian (Fireblocks or HexTrust). Fiat client funds are held in segregated accounts with licensed Swiss banking partners during the settlement cycle. All platform events generate an immutable audit log accessible to the bank. Fuze Finance's identity is documented in the bank-to-Fuze Finance agreement and in the bank's regulatory filings; it is not surfaced to the end client in the standard transaction flow.

Fully Disclosed Architecture

The structure is operationally identical to the white-label model, with one material difference: Fuze Finance's role as the execution and settlement infrastructure provider is disclosed to the end client through the bank's reporting and documentation. The client knows they are transacting with the bank and that Fuze Finance is the execution partner. Execution terms, pricing, and the identity of the infrastructure layer are transparent. The bank's regulatory filings and client-facing documentation identify Fuze Finance as the disclosed VASP partner. This is the model required under SO-FIT's financial intermediary framework in Switzerland, where Fuze Finance (Switzerland) AG operates as the disclosed execution partner alongside the banking institution.

01. White-Label Architecture



01 Licensing

Licenses are held by the partner bank, and the bank is counterparty to trades

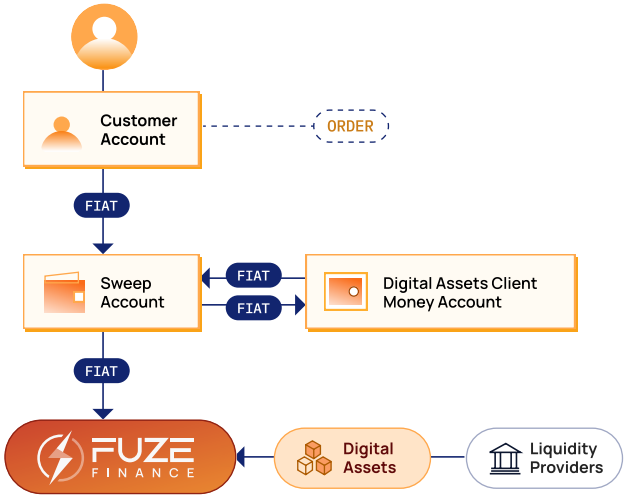
02 Onboarding

The bank owns the customers; Fuze Finance does not KYC the customers onboarded

03 Branding

Fully bank-branded experience; Fuze Finance is invisible to the end customer

02. Fully Disclosed Architecture



01 **Licensing**

Fuze Finance holds the license and performs all trading activity and is the counterparty

02 **Onboarding**

Fuze Finance onboards the customers and performs KYC for all customers onboarded

03 **Branding**

Fuze Finance-powered experience within the bank's platform; customer signs

- Reference Architectures — White-Label (Image 1) and Fully Disclosed (image 2): account structure, asset and fiat flows, and the licensing, onboarding, and branding split between bank and Fuze Finance

Appendix E: About Fuze Finance and Halborn

Fuze Finance is a B2B technology platform enabling clients to launch regulated digital assets products, including digital asset trading, transfer, and settlement.

Fuze Finance enables banks and fintechs to integrate digital asset products natively into their own channels and offer to its customers in a regulated and compliant fashion. Fuze Finance's orchestration platform also offers best-in-class custodians and liquidity providers to our clients and partners.

Fuze Finance obtained its SO-FIT affiliation in Switzerland in July. Globally, the business is regulated in the UAE as a Broker-Dealer under the Dubai Virtual Assets Regulatory Authority (VARA), hava a RPS license from the UAE Central Bank (CBUAE). Fuze Finance is also also part of a regulatory sandbox in Jordan by the Jordan Central Bank (CBJ), has an operational approval in Türkiye, and is registered as a MSB in Canada.

Halborn is an industry-leading blockchain security firm for enterprise-grade digital assets, trusted by the world's largest banks and financial institutions. Halborn provides end-to-end security solutions from smart contract assessments and penetration testing, to advisory services: everything institutions need to innovate securely. With 3,000+ engagements completed and several zero-day discoveries, the firm has protected over $1 trillion in value.